

zØmbie zØne

Parc d'attractions fictif post-apocalyptique

CAHIER DES CHARGES

Application web fullstack TypeScript — SPA + API REST

Candidat : Stéphane Rochard

Formation O'clock — CDA RNCP37873 Niveau 6

Soutenance : 9 juin 2026

Production : sharo.fr | API : sharo.fr/api/docs | Code : github.com/5h4r0/z0mbiez0ne

1. Présentation du Projet

Nom du projet	zØmbie zØne
Type	Application web fullstack — SPA + API REST
Objectif	Vitrine immersive + réservation de billets par sessions d'activités + backoffice admin
Production	sharo.fr
API Docs	sharo.fr/api/docs
GitHub	github.com/5h4r0/z0mbiez0ne

2. Cibles du Projet

Public principal : adolescents et jeunes adultes (16-30 ans).

Contraintes ergonomiques

- Design immersif et moderne adapté au thème horrifique
- Mobile-first — utilisation mobile importante
- Navigation rapide et intuitive
- Accessibilité RGAA 2.1 à 60% minimum

3. Définition des Besoins

Besoins identifiés

- Manque de visibilité du parc auprès du public ciblé
- Besoin d'un système en ligne simple et fiable pour réserver des billets par session d'activité
- Nécessité pour le gérant de gérer le site de manière autonome

Objectifs du MVP

- Site web immersif avec design adapté au thème horrifique
- Affichage détaillé des catégories, activités, sessions (date/heure, capacité, statut, places disponibles)
- Système de réservation de sessions d'activité
- Espace client : historique des commandes avec dates des sessions, annulation
- Backoffice admin sécurisé : CRUD catégories, activités, sessions, comptes utilisateurs, commandes
- Site mobile-first responsive
- Accessibilité RGAA 2.1 minimum 60%
- Bonnes pratiques SEO

4. User Stories du MVP

Utilisateur / Membre

En tant que	Je dois pouvoir	Afin de
utilisateur	Lister toutes les catégories	Consulter des activités par catégorie
utilisateur	Lister toutes les activités	Choisir une activité et consulter les sessions
utilisateur	Consulter le détail d'une activité	Voir description, prix et sessions associées
utilisateur	Consulter la liste des sessions d'une activité	Choisir une date/heure précise
utilisateur	Créer un compte avec le rôle member	Accéder à l'espace membre
utilisateur	Se connecter / Se déconnecter	Sécuriser sa session
utilisateur	Réinitialiser son mot de passe	Sécurisation ou oubli du mot de passe
utilisateur	Supprimer son compte (soft delete)	Effacer ses données personnelles — RGPD
membre	Gérer son panier (add/remove/quantité)	Préparer sa commande
membre	Confirmer ou annuler sa commande	Finaliser ou abandonner sa commande
membre	Consulter ses commandes passées et en cours	Voir l'historique et le détail
membre	Modifier son profil, changer son mot de passe	Gérer son compte

Administrateur

En tant que	Je dois pouvoir	Afin de
admin	Se connecter / Se déconnecter	Sécuriser l'accès au backoffice
admin	CRUD catégories (blocage si activité liée)	Gérer le catalogue
admin	CRUD activités + upload images WebP	Gérer les activités du parc
admin	CRUD sessions (blocage si commandes liées)	Gérer le planning
admin	Lire / modifier tous les utilisateurs	Gérer les comptes membres
admin	Lire / modifier le statut de toutes les commandes	Gérer les réservations

5. Contraintes Techniques et Qualité

Contraintes techniques

- JWT access token (15 min) + refresh token (7 j) — cookies httpOnly exclusivement, jamais localStorage
- Validation Zod sur tous les inputs body/params/query
- argon2id pour le hachage des mots de passe
- 151 tests automatisés (116 intégration + 35 unitaires) — CI verte obligatoire avant merge
- Docker multi-stage — GitHub Actions CI/CD

Contraintes qualité & conformité

Contrainte	Exigence
Responsive	Mobile-first, breakpoints CSS dans le design system
Accessibilité	RGAA 2.1 minimum 60% — attributs ARIA, contrastes, navigation clavier
RGPD	Soft delete users/orders, consentement cookies (Klaro), mentions légales
Éco-conception	Images WebP (Sharp), lazy loading, pagination, select Prisma explicite
SEO	Slugs auto-générés, balises meta, structure sémantique HTML5
Sécurité	OWASP Top 10 — validation Zod, argon2id, JWT httpOnly, CORS strict
Déploiement	Docker multi-stage, CI/CD GitHub Actions, VPS Ionos documenté (DEPLOY.md)
Headers HTTP	X-Frame-Options, HSTS, X-Content-Type-Options, Referrer-Policy (Nginx)

6. Architecture du Projet

Architecture retenue

Couche	Description
Présentation	SPA React 19 + Vite — React Router 7, Zustand, apiFetch intercepteur 401, cookies httpOnly (jamais localStorage)
Métier	Express 5 API REST TypeScript — routes → middlewares (Zod, requireAuth, requireRole) → controllers → helpers
Accès données	Prisma 5 ORM — requêtes paramétrées, select explicite, \$transaction, soft delete RGPD
Persistance	PostgreSQL 16 — contraintes FK, normalisation 3NF, BDD test isolée, migrations versionnées
Sécurité	JWT httpOnly+Secure+SameSite=Strict, argon2id, Zod, CORS strict, headers Nginx

Couche	Description
Infrastructure	Docker Compose multi-stage, Nginx reverse proxy + SSL Let's Encrypt, GitHub Actions CI/CD, VPS Ionos

Zones de l'application

Zone	URL	Description
Site vitrine	sharo.fr	Activités, sessions, catégories, contact
Espace client	sharo.fr/dashboard	Compte, commandes, annulation
Backoffice admin	sharo.fr/manage	Gestion activités, sessions, utilisateurs

7. Stack Technique

Back-end

Technologie	Rôle	Justification
Node.js 22 + Express 5	API REST	Runtime JS natif async/await, Express 5 : meilleure gestion erreurs async
TypeScript 5 strict	Typage statique	Zéro any, détection erreurs à la compilation, interfaces partagées back/front
Prisma 5	ORM	Schéma déclaratif, migrations versionnées, client typé, select explicite anti-fuite données
PostgreSQL 16	Base de données	SGBDR ACID, FK robustes, idéal pour données relationnelles à forte cohérence
Zod	Validation inputs	Validation runtime tous inputs + inférence types TypeScript
argon2id	Hachage mots de passe	Résistant GPU/ASIC — recommandé OWASP 2023, supérieur à bcrypt
jsonwebtoken	JWT	Access token 15 min + refresh token 7 j, auth stateless
date-fns	Manipulation dates	Légère, tree-shakeable, utilisée dans les controllers sessions/orders
Biome 2.x	Linter + formateur	Remplace ESLint + Prettier, ~10x plus rapide, unifié back + front
Nodemailer	Emails	Vérification email, reset password, confirmation commande — SMTP Ionos

Front-end

Technologie	Rôle	Justification
React 19 + Vite 6	SPA	HMR natif, code splitting, tree-shaking, React concurrent features
React Router 7	Routing	Navigation SPA, routes protégées, loaders
Zustand	State global	Store minimaliste sans boilerplate, persist optionnel (panier uniquement)
TypeScript 5 strict	Typage statique	Cohérence avec le back, interfaces partagées
Tailwind v4	CSS	Utility-first, breakpoints custom dans @theme
Biome 2.x	Linter + formateur	Uniformité avec le back, exécution depuis vite-frontend/

Infrastructure

Technologie	Rôle
Docker multi-stage	Builder (node:22 + tsc) → Runner (node:22-alpine, dist/ uniquement)
Nginx	Reverse proxy, SSL termination, redirect HTTP → HTTPS, SPA fallback, headers sécurité
Let's Encrypt + Certbot	Certificats SSL — renouvellement automatique
GitHub Actions	Pipeline CI/CD : lint → tests → build → deploy SSH
VPS Ionos	Ubuntu 24.04 LTS, 2 vCPU / 2 GB RAM / 80 GB NVMe, IP 82.165.180.54
Vitest + Supertest	Tests : runner TypeScript natif, Supertest monte Express en mémoire sans port réseau
Stripe API	Paieement sécurisé — hors MVP, prévu V2

8. Modèle de Données

Entités principales

Entité	Description
roles	Rôles utilisateur (member, admin)
users	Comptes utilisateurs — soft delete (deleted_at) — RGPD
RefreshToken	Tokens de rafraîchissement JWT — token_id UUID + hash argon2 du JWT
EmailVerificationToken	Tokens de vérification d'email à l'inscription
categories	Catégories d'activités — hard delete (libère les images)
activities	Activités du parc — hard delete (libère les images)
activities_categories	Table de jonction activité ↔ catégorie (M-N)
sessions	Sessions planifiées d'une activité — hard delete
orders	Commandes utilisateur — soft delete (deleted_at) — RGPD
orders_lines	Lignes de commande — unit_price_ht et vat_rate figés à la commande

Choix de conception notables

- Soft delete (deleted_at) sur users et orders uniquement — traçabilité RGPD et conservation pour audit
- Hard delete sur activities, sessions, categories — libère les fichiers images associés
- unit_price_ht + vat_rate figés dans orders_lines — historique immuable des prix
- token_id UUID dans RefreshToken — lookup par index, hash argon2 du JWT en base
- slug auto-généré sur activities et categories — URLs SEO-friendly

Enums

Enum	Valeurs
OrderStatus	Pending → Confirmed, Pending → Cancelled, Confirmed → Refunded
SessionStatus	Scheduled, Cancelled, Completed

9. Fonctionnalités Hors MVP — Évolutions Potentielles

- Paiement sécurisé CB via Stripe (prévu V2 — architecture l'anticipe)
- Rate limiting express-rate-limit sur /api/auth/* (protection anti-brute-force)
- Tests E2E Playwright — flow complet navigateur login → réservation → confirmation
- Emails transactionnels complets — confirmation commande avec détail lignes HT + TTC
- i18n FR/EN — prévu dans l'architecture (routes /fr et /en), non implémenté
- RGAA complet — audit accessibilité pour dépasser 60%

- Système de messagerie interne
- Notation des activités + commentaires (avec modération admin)
- Notifications push/email
- Boutique e-commerce de produits dérivés
- Support multilingue

10. Analyse des Risques

Risque	Impact	Mesure préventive
Délais de développement	Élevé	Planification agile avec sprints courts, Definition of Done stricte
Bugs critiques sur commande	Élevé	Tests d'intégration Supertest + transaction Prisma atomique sur createOrder
Faible de sécurité (XSS, injection SQL)	Élevé	Validation Zod + Prisma paramétré + JWT httpOnly + argon2id + OWASP Top 10
Problème de déploiement	Moyen	DEPLOY.md + Docker multi-stage + CI/CD avec fail-fast + procédure de rollback
Race condition sur refresh token	Moyen	Promise singleton refreshPromise dans apiFetch — résolu
bfcache restauration page protégée	Moyen	Cache-Control no-store + guard réseau au montage — résolu

11. Gestion de Projet

Répartition des rôles (projet solo)

Rôle	Candidat	Responsabilités
Product Owner	Stéphane Rochard	Vision produit, priorisation backlog, user stories
Scrum Master	Stéphane Rochard	Organisation des sprints, Definition of Done
Lead Dev / Architecte	Stéphane Rochard	Stack, patterns, conventions, sécurité
Dev Back-End	Stéphane Rochard	API REST, JWT, BDD, tests
Dev Front-End	Stéphane Rochard	SPA React, routing, state management
DevOps / QA	Stéphane Rochard	Docker, CI/CD, VPS, documentation technique

Versioning et bonnes pratiques

- Git — branche master (prod), branches dédiées par feature/fix
- Commits conventionnels EN : feat/fix/chore/docs/test/refactor/ci/build
- Jamais de commit direct sur master — CI verte obligatoire avant merge
- 244 commits, 24 Pull Requests mergées

Planning des sprints

Sprint	Thème	Livrables principaux
Sprint 1	Setup & API base	Monorepo npm workspaces, schéma Prisma,

Sprint	Thème	Livrables principaux
		migrations, API categories/activities/sessions, seeding @faker-js
Sprint 2	Authentification	JWT httpOnly, register/login/refresh/logout, middlewares requireAuth/requireRole
Sprint 3	Orders & Frontend	Commandes, panier Zustand, espace client React Router 7, apiFetch intercepteur 401
Sprint 4	Admin & Déploiement	Backoffice CRUD admin, Docker multi-stage, CI/CD GitHub Actions, VPS Ionos
Sprint 5	Tests & Hardening	151 tests Vitest + Supertest, audit sécurité, corrections anomalies, Swagger/OpenAPI